Technischer Zwischenbericht

Autorisierte, passive Sicherheitsprüfung – Karolinen-Gymnasium Rosenheim

Stand: 26. Oktober 2026 | **Status:** Zwischenstand, nicht abschließend verifiziert

1. Zusammenfassung

Öffentlich erreichbare Seiten der Schulwebsite wurden manuell betrachtet und mit OWASP ZAP 2.17.0 im passiven Modus ausgewertet. Der integrierte ZAP-Browser wurde für normale Seitenaufrufe verwendet. Es wurden keine aktiven Scans oder gezielten Angriffstests durchgeführt.

ZAP meldete mehrere Hinweise zu HTTP-Sicherheitsheadern und eine veraltete jQuery-Bibliotheksversion. Diese Hinweise sind keine automatischen Beweise für ausnutzbare Schwachstellen. Bisher wurde keine ausnutzbare Schwachstelle bestätigt.

Die Schulwebsite verwendet HTTPS; laut Nutzer leitet HTTP auf HTTPS um. In mindestens einer untersuchten Antwort war `X-Content-Type-Options: nosniff` vorhanden. Header-Ergebnisse müssen pro URL und Antworttyp bewertet werden.

2. Umfang und Grenzen

System	Bisheriger Umfang
Schulwebsite karolinen-gymnasium-rosenheim.de	Öffentliche Seiten, normale Aufrufe, passive ZAP-Analyse und ausgewählte Response-Header aus DevTools.
Schülerportal schueler.schule-infoportal.de	Öffentliche Login-Seite und PWA-Metadaten beobachtet; keine Anmeldung oder Prüfung geschützter Funktionen.
Elternportal karogyro.eltern-portal.org	Öffentliche Login-Seite betrachtet; keine Anmeldung oder Prüfung geschützter Funktionen.

Der Nutzer gibt an, dass eine schriftliche Genehmigung vorliegt; diese wurde nicht unabhängig geprüft. Die Portale sind externe Dienste und als separate Systeme zu behandeln. Weitergehende Prüfungen müssen innerhalb des konkreten Genehmigungsumfangs bleiben.

Nicht durchgeführt: aktive Scans, Exploit-Versuche, Authentifizierungs- oder Berechtigungsumgehungen, Belastungstests sowie Tests mit realen Schüler- oder Elterndaten. Dies ist keine vollständige Sicherheitsbewertung.

3. Methodik und Reproduzierbarkeit

- Werkzeug: OWASP ZAP 2.17.0 unter Windows; integrierter Browser; passiver Scan.
- Testverhalten: normale Seitenaufrufe; keine aktiven Scan- oder Angriffsfunktionen gestartet.
- Evidenz: sichtbare ZAP-Alertdetails und ausgewählte HTTP-Response-Header aus Browser-Entwicklertools.
- Risikostufen und Confidence werden als ZAP-Meldungen wiedergegeben und sind keine unabhängige Bestätigung der Ausnutzbarkeit.

4. Technische Befunde

F-01 – Content Security Policy (CSP) Header Not Set

ZAP: Medium; Confidence High. Für die untersuchte Startseitenantwort wurde kein CSP-Header erkannt. Eine CSP kann zulässige Quellen für Skripte und andere Ressourcen einschränken. **Empfehlung:** CSP-Abdeckung prüfen und eine passende Policy zunächst im Report-Only-Modus testen. Die Ausnutzbarkeit wurde nicht geprüft.

F-02 – Strict-Transport-Security Header Not Set (Systemic)

ZAP: Low; Confidence High. HSTS wurde bei mehreren beobachteten Antworten nicht erkannt. HTTPS ist aktiv und HTTP leitet laut Nutzer auf HTTPS um. **Empfehlung:** HSTS auf relevanten HTTPS-Antworten prüfen; Laufzeit und Subdomain-Abdeckung sorgfältig festlegen.

F-03 – Vulnerable JS Library: jQuery 2.2.4

ZAP: Medium; Confidence Medium. ZAP/Retire.js erkannte jQuery 2.2.4 und nannte CVE-2020-11022 sowie CVE-2020-11023. Die Version ist veraltet und mit bekannten Sicherheitsproblemen verbunden. **Empfehlung:** Version und Abhängigkeiten verifizieren und eine aktuelle unterstützte Version nach Kompatibilitätstests einsetzen. Es wurde nicht geprüft, ob verwundbare Funktionen mit nicht vertrauenswürdigen Inhalten verwendet werden.

F-04 – Missing Anti-clickjacking Header

ZAP: Medium; Confidence Medium. In der untersuchten Antwort wurde kein X-Frame-Options-Header erkannt. Eine CSP-Direktive `frame-ancestors` wurde für diesen Befund nicht separat verifiziert. **Empfehlung:** Einbettungspolitik prüfen und gegebenenfalls X-Frame-Options und/oder CSP frame-ancestors konfigurieren.

5. Weitere Alerts – noch nicht im Detail verifiziert

ZAP zeigte außerdem: Cross-Domain Misconfiguration (2); X-Content-Type-Options Header Missing; Timestamp Disclosure – Unix (2); Information Disclosure – Suspicious Comments (7); Modern Web Application; Re-examine Cache-control Directives (3). Diese Einträge werden hier nicht als bestätigte Schwachstellen gewertet.

Der Alert zu fehlendem X-Content-Type-Options steht neben einer separat beobachteten Antwort mit `nosniff`. Das kann durch unterschiedliche Ressourcen oder Antworttypen erklärbar sein. Betroffene URLs und Responses sollten abgeglichen werden.

6. Weitere Beobachtungen ohne bestätigte Schwachstelle

• Ein Cookie namens `in2cookiemodal-selection` wurde beobachtet. Zweck und Sicherheitsattribute wurden nicht abschließend verifiziert; daraus wird kein eigenständiger Befund abgeleitet.
• Das Schülerportal zeigte erwartbare PWA-Merkmale; ein Service Worker war als aktiviert angezeigt. Das ist kein Schwachstellenbeleg.
• Eine einzelne HTTP-304-Antwort reicht nicht aus, um das generelle Vorhandensein oder Fehlen von Sicherheitsheadern zu beurteilen.
• Server-/TYPO3-bezogene Header wurden beobachtet. Plattformhinweise allein belegen keine Schwachstelle.

7. Priorisierte Empfehlungen

Priorität 1 – Bibliothek: jQuery 2.2.4 und die genannten CVEs durch den Betreiber prüfen und die Bibliothek bei Bedarf aktualisieren.
Priorität 2 – Header: CSP, HSTS und Anti-Clickjacking-Schutz pro relevanter Antwort prüfen und Änderungen zunächst in einer Testumgebung validieren.
Priorität 3 – Antwortunterschiede: Cross-Domain-, nosniff- und Cache-Control-Hinweise anhand konkreter URLs und Response-Typen überprüfen.
Priorität 4 – Nachprüfung: Nach freigegebenen Änderungen passive Requests erneut prüfen und Datum sowie relevante Header dokumentieren.

8. Vorläufiges Fazit

Die passive Prüfung hat mehrere Konfigurationshinweise ergeben, die der verantwortliche Betreiber überprüfen sollte. Besonders relevant sind die erkannte jQuery-Version 2.2.4 und die gemeldeten fehlenden Schutzheader. Die Ausnutzbarkeit wurde nicht getestet. Aus den bisherigen Daten kann weder vollständige Sicherheit noch eine erfolgreiche Ausnutzung abgeleitet werden.

Nächster vorgesehener Schritt: den Alert „Cross-Domain Misconfiguration (2)“ anhand der Detailansicht einordnen; danach bei Bedarf den nosniff- und Cache-Control-Hinweisen nachgehen.

Dokumentstatus: aktualisierter Zwischenbericht. Die Prüfung ist noch nicht abgeschlossen; der Bericht ersetzt keinen abschließenden Pentest-Bericht.